

## Manual 54 — AI Model Risk Management & Independent Validation

Controlled publication source — English

Verification date: 1 September 2026

Release status: candidate source

### Purpose

This manual establishes a practical independent-validation and model-risk-management program for predictive AI, generative AI, RAG systems and agentic AI. It combines enterprise AI-risk principles with fit-for-purpose test, evaluation, verification and validation (TEVV) methods while preserving the actual scope and status of each source.

### Source-status discipline

NIST AI RMF 1.0 remains voluntary guidance and is under revision. NIST AI 200-2 TEVV-Athlon is an Initial Public Draft as of August 2026 and is treated as emerging evaluation guidance, not a final mandatory standard. NIST AITE is a voluntary evaluation program. For U.S. banking organizations, Federal Reserve SR 26-2 and the 2026 interagency Revised Guidance on Model Risk Management supersede SR 11-7; that supervisory guidance is sector-specific and does not become a universal legal requirement for non-banks. The revised guidance emphasizes a risk-based approach tailored to model risk profile, size and complexity.

### Validation operating model

Use case/materiality → inventory → assumptions/limitations → data → methodology/implementation → performance/robustness → security/fairness/explainability → GenAI/RAG/agentic tests → human oversight → third-party challenge → findings/disposition → monitoring/revalidation.

### MRM-01 — Use-case and materiality classification

Validate business purpose, affected stakeholders, decision consequence, autonomy, data sensitivity, financial or operational impact, regulatory exposure and reversibility. Record materiality, accountable owner, approval tier and escalation path.

### MRM-02 — Model and system inventory

Validate model/provider/version, orchestration, system prompts, retrieval stores, tools, agents, data pipelines, hosting and dependencies. Inventory the complete AI system, not only the mathematical or foundation model.

### MRM-03 — Assumptions and limitations

Identify explicit and implicit assumptions, supported operating ranges, uncertainty, known failure modes, prohibited uses, edge conditions and reliance on third-party claims. Independent validators must challenge material assumptions rather than merely restating developer documentation.

#### **MRM-04 — Data validation**

Assess provenance, lineage, representativeness, data quality, leakage, duplication, contamination, label integrity, temporal relevance, sensitive-data handling and train/test separation where applicable. Document limitations and data conditions that would invalidate performance conclusions.

#### **MRM-05 — Methodology and implementation**

Assess whether the selected methodology is appropriate for the intended use and whether production implementation matches the approved design. Use reproducibility, code/configuration review, independent calculations or alternate methods where proportionate to materiality.

#### **MRM-06 — Performance and robustness**

Test task performance using fit-for-purpose metrics, uncertainty, stress cases, distribution shift, edge cases, stability, calibration where relevant and explicit failure thresholds. Avoid relying on a single aggregate benchmark when consequential subgroup or scenario failures could be hidden.

#### **MRM-07 — Security and adversarial resilience**

Challenge prompt injection, poisoning, exfiltration, unsafe output execution, tool abuse, privilege escalation, supply-chain integrity, provider changes, denial/resource exhaustion and containment capability where relevant. Link validation findings to Manual 52 security evidence.

#### **MRM-08 — Fairness and harmful-bias evaluation**

Where relevant to use case and applicable requirements, evaluate subgroup performance, disparate-impact indicators, proxy effects, data imbalance and mitigation effectiveness. Document when a fairness metric is not applicable and why; do not imply one metric proves absence of harmful bias.

#### **MRM-09 — Explainability and decision traceability**

Validate whether explanations, evidence attribution, provenance, decision records and human-facing rationales are suitable for the use case and stakeholder need. Do not represent explanation techniques as revealing internal truth beyond their actual capability.

#### **MRM-10 — GenAI factuality, groundedness and hallucination risk**

Define task-specific factuality and groundedness tests, reference-source expectations, citation/provenance checks, unsupported-claim thresholds, abstention behavior, uncertainty handling and escalation rules. Evaluate realistic workflows, not only benchmark prompts.

#### **MRM-11 — RAG retrieval quality and authorization**

Validate source eligibility, retrieval relevance, freshness, authorization, tenant isolation, chunking/indexing behavior, poisoning resistance, citation fidelity and unauthorized retrieval prevention. Measure both answer quality and the integrity of retrieved evidence.

### **MRM-12 — Agentic action risk**

Validate agent identity, delegated authority, tool permissions, action boundaries, human approval thresholds, cross-agent delegation, transaction/resource limits, rollback, containment and attributable logs. Test whether safeguards hold under adversarial or ambiguous instructions.

### **MRM-13 — Human oversight effectiveness**

Test whether assigned reviewers can understand, intervene, reject, override, stop, escalate and document decisions before consequential action. A nominal human in the workflow is not sufficient if technical or process design prevents meaningful intervention.

### **MRM-14 — Third-party dependency validation**

Challenge provider claims, model cards, security statements, change notices, contractual commitments, service continuity, version controls, exit options and evidence availability. Record which claims were independently reproduced and which remain dependent on supplier assertions.

### **MRM-15 — Monitoring and revalidation**

Define metrics, drift thresholds, incidents, provider/model/data/tool changes, control failures, performance degradation and time-based triggers requiring revalidation. Revalidation scope must reflect the materiality of the change rather than defaulting to either full revalidation or no review.

### **MRM-16 — Findings, conditional approval and disposition**

Classify findings by severity and materiality. Track remediation, compensating controls, accepted residual risk, conditional approval, use restrictions, expiration dates and closure evidence. Unresolved high-severity findings require explicit accountable disposition; validation teams must be able to document dissent.

### **Independence criteria**

Independent validation should be organizationally and intellectually separate from primary system development to a degree proportionate to materiality. Validators must be able to challenge assumptions, reproduce or independently test claims, document dissent, escalate unresolved findings and avoid validating their own substantive design decisions without compensating governance.

### **Required scenario pack**

#### **Scenario 1 — Distribution shift**

Upstream data distribution changes and model performance deteriorates. Test monitoring sensitivity, materiality assessment, revalidation trigger and business response.

#### **Scenario 2 — Silent provider version change**

A hosted model changes without effective internal notice. Test version detection, regression evaluation, change governance and rollback.

### Scenario 3 — Consequential GenAI hallucination

A fluent but unsupported claim appears in a consequential workflow. Test groundedness metrics, source verification, abstention, human escalation and incident thresholds.

### Scenario 4 — RAG retrieves stale or unauthorized evidence

Test source eligibility, access control, freshness, ranking, citation fidelity, deletion propagation and user-visible provenance.

### Scenario 5 — Agent action outside approved boundary

Test identity, authorization, approval threshold, tool restrictions, transaction limits, rollback and evidence.

### Scenario 6 — Ineffective human oversight

A reviewer is nominally assigned but cannot intervene before consequence. Test timing, authority, information quality, interface and technical stop controls.

### Scenario 7 — Evaluation contamination

Training or tuning data overlaps evaluation data and inflates apparent performance. Test provenance, leakage detection, blind/sequestered evaluation where appropriate and reproducibility.

### Scenario 8 — Third-party claim cannot be reproduced

Challenge vendor performance or safety claims using independent data, alternate methods and uncertainty reporting.

### Scenario 9 — Conditional approval with open security finding

Evaluate whether compensating controls, use restrictions, expiration and executive risk acceptance are adequate and enforceable.

### Scenario 10 — Material drift below a hard threshold

Monitoring shows a meaningful risk-profile change that has not breached an existing numeric limit. Test whether governance can escalate based on materiality rather than waiting for a threshold breach.

## Evidence catalogue

- EV-01 Validation charter and scope.
- EV-02 Use-case/materiality assessment.
- EV-03 Model/system inventory.
- EV-04 Architecture and data-flow diagrams.
- EV-05 Assumptions/limitations register.
- EV-06 Data-quality/provenance tests.
- EV-07 Reproducible performance results.
- EV-08 Robustness/stress tests.
- EV-09 Adversarial/security test results.
- EV-10 Fairness assessment where applicable.
- EV-11 GenAI factuality/groundedness evaluation.
- EV-12 RAG retrieval/authorization evaluation.
- EV-13 Agentic action-boundary tests.

- EV-14 Human-oversight effectiveness test.
- EV-15 Third-party evidence challenge.
- EV-16 Findings/remediation register.
- EV-17 Conditional approval or residual-risk record.
- EV-18 Monitoring and revalidation plan.

### Release rule

Validation is not a one-time approval stamp. Evidence must demonstrate independent challenge, reproducible or otherwise supportable testing, clear findings, accountable disposition and defined revalidation triggers. Emerging draft guidance must remain labeled as draft and sector supervisory guidance must retain its actual scope.